

CRIMSON CLINIC PENETRATION TEST

CDCTF Penetration Test

Προχωρούμε
Nick Sheldon
Misha Semenov

Contacts

Crimson Clinic

Name	Role	Email
CDCTF Team	Organizer	
Jefferry Barret	CFO	

Προχωρούμε

Name	Role	Email
FiveWings	Captain	cu_fivewings@cdctf.invalid
Euthus	Penetration Tester	cu_euthus@cdctf.invalid
taciturnaxolotl	Penetration Tester	cu_.taciturnaxolotl@cdctf.invalid
ArcherDan	Penetration Tester	cu_archerdan@cdctf.invalid

Confidential and Proprietary – Do not duplicate or distribute

Table of Contents

Contacts 1

Crimson Clinic 1

Προχωρούμε 1

Table of Contents 2

Statement of Confidentiality 3

Liability Disclosure 3

Executive Summary 4

Key Strengths 4

Key Weaknesses 4

Strategic Recommendations 4

Introduction 5

Scope 5

Methodology 5

Findings 6

Critical Findings 7

Predictable Password and Insufficient Online Guessing Resistance 7

High Findings 11

Document Backed Vishing Pretex 11

Appendix A: CVSS Severity and Risk Classifications 14

Confidential and Proprietary – Do not duplicate or distribute

Statement of Confidentiality

This assessment and report were created in conjunction with Crimson Clinic Information Technology and Management teams and the Cedarville University Cyber Center under the terms laid out in the Scope of Work document agreed upon by all parties. As such, all information in this report is and should be considered confidential and proprietary. This includes but is not limited to assessment goals, assessment findings, report conclusions, and environment details such as services, vulnerabilities, and future recommendations and remediations. This report should only be used for internal use and under the authorization of those within Crimson Clinic and the CDCTF Team.

Liability Disclosure

Προχωρούμε has made reasonable effort to test the application(s) thoroughly and report on any vulnerabilities found in the application(s) at the time of testing. However, due to limitations of scope and time, this assessment should not be taken as a comprehensive listing of all security vulnerabilities that exist on the system and the environment. Additionally, this report only acts as an assessment of the application(s) at the time of testing as outlined in the Scope of Work document. Προχωρούμε shall not be held responsible or liable for any incidents that are a result of undiscovered vulnerabilities or flaws, future vulnerabilities, incorrect remediation techniques, or future configurations.

Confidential and Proprietary – Do not duplicate or distribute

Executive Summary

Προχωρούμε performed a penetration test of the Crimson Clinic challenge environment with emphasis on the Social Engineering series and authentication controls. The assessment included a document-backed vishing pretext, targeted open-source intelligence collection, and a controlled low-rate authentication test. The assessment was performed as an authorized CTF exercise. During the assessment, the team obtained administrative access through a predictable password constructed from publicly obtainable biographical information. Captured application views showed access to employee, payroll, reporting, patient, prescription, and hospital-record functions. A separate social-engineering path demonstrated that visual elements from an online diploma could be reused and AI-edited to support a plausible identity-verification pretext.

Although there were many notable strengths in the design and implementation of security, several high risk issues were found that leave Crimson clinic and it's users at risk of compromise.

Key Strengths

The application enforced distinct administrative and clinical areas after authentication, which made the privilege context visible during validation. The team also limited testing to non-destructive review and did not export, alter, approve, or delete data.

Key Weaknesses

The administrative password could be predicted from public personal information and a common construction pattern. The observed success of a request every approximately twenty seconds demonstrated inadequate resistance to targeted online guessing. The identity-verification scenario also relied too heavily on the visual credibility of a submitted document.

Strategic Recommendations

προχωρούμε recommends implementing phishing-resistant multi-factor authentication for privileged and clinical accounts, screening passwords against breached and predictable patterns, and enforcing account and source-based login throttling. Identity-verification procedures should require independent confirmation through a pre-registered contact method and should not accept a submitted document image as the sole proof of identity.

Confidential and Proprietary – Do not duplicate or distribute

Introduction

προχωρούμε was tasked with assessing the security posture of the Crimson Clinic challenge environment. The testing focused on the confidentiality and integrity risks created by social engineering and authentication failures. The report documents what the team observed, the likely business impact, and practical remediation actions.

Before testing occurred, Προχωρούμε met with two members of Crimson Clinic, Sydney Krueger and Elisa Boothe, to discuss the Scope of Work document, the functionality of the web application, and obtaining source code of the web application. This meeting occurred on March 23rd, 2026 at 4:00 pm. After the meeting, Προχωρούμε began the engagement.

Scope

The in-scope activities were

- document-based pretext creation
- public-information research (OSINT)
- a small targeted credential wordlist
- controlled authentication attempts
- review of functions available after successful authentication

The full recovered password and the supplied doctor credentials are intentionally omitted from this report and should be treated as compromised secrets. The following actions were out of scope for this report: destruction or modification of data, bulk data extraction, prescription approval or alteration, malware delivery, persistence, denial of service, and testing against systems outside the challenge environment.

Methodology

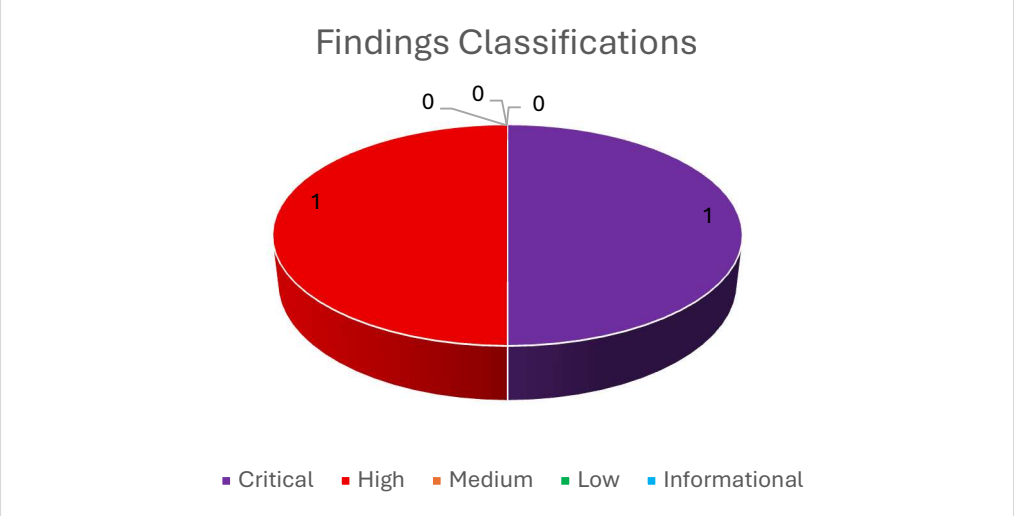
The team first researched publicly available information related to the affected administrative user. The collected interests and a family birth year were used to build a small targeted candidate list. A script submitted one candidate approximately every twenty seconds and recorded the HTTP response code. After a successful response, the team reviewed accessible functions without taking destructive action. For the social-engineering scenario, the team located a diploma online, captured the header and footer as images, used AI-assisted editing to remove background color and make the text black, added attacker-authored body content, and submitted the document as part of the vishing pretext.

Confidential and Proprietary – Do not duplicate or distribute

Findings

This section contains the findings discovered during the assessment. Each finding includes a severity and risk rating, a description, affected assets, business impact, remediation recommendations, and references. CVSS values are provisional estimates based on the challenge evidence and should be recalculated if the exact production impact boundary is known.

During the assessment, Προχωρούμε discovered a total of 1 **Critical**, 1 **High**, 0 **Medium**, 0 **Low**, and 0 **Informational** findings as rated by the CVSS standard. These reflect the security flaws at the time of testing. A breakdown of the vulnerabilities found can be found in the chart below.

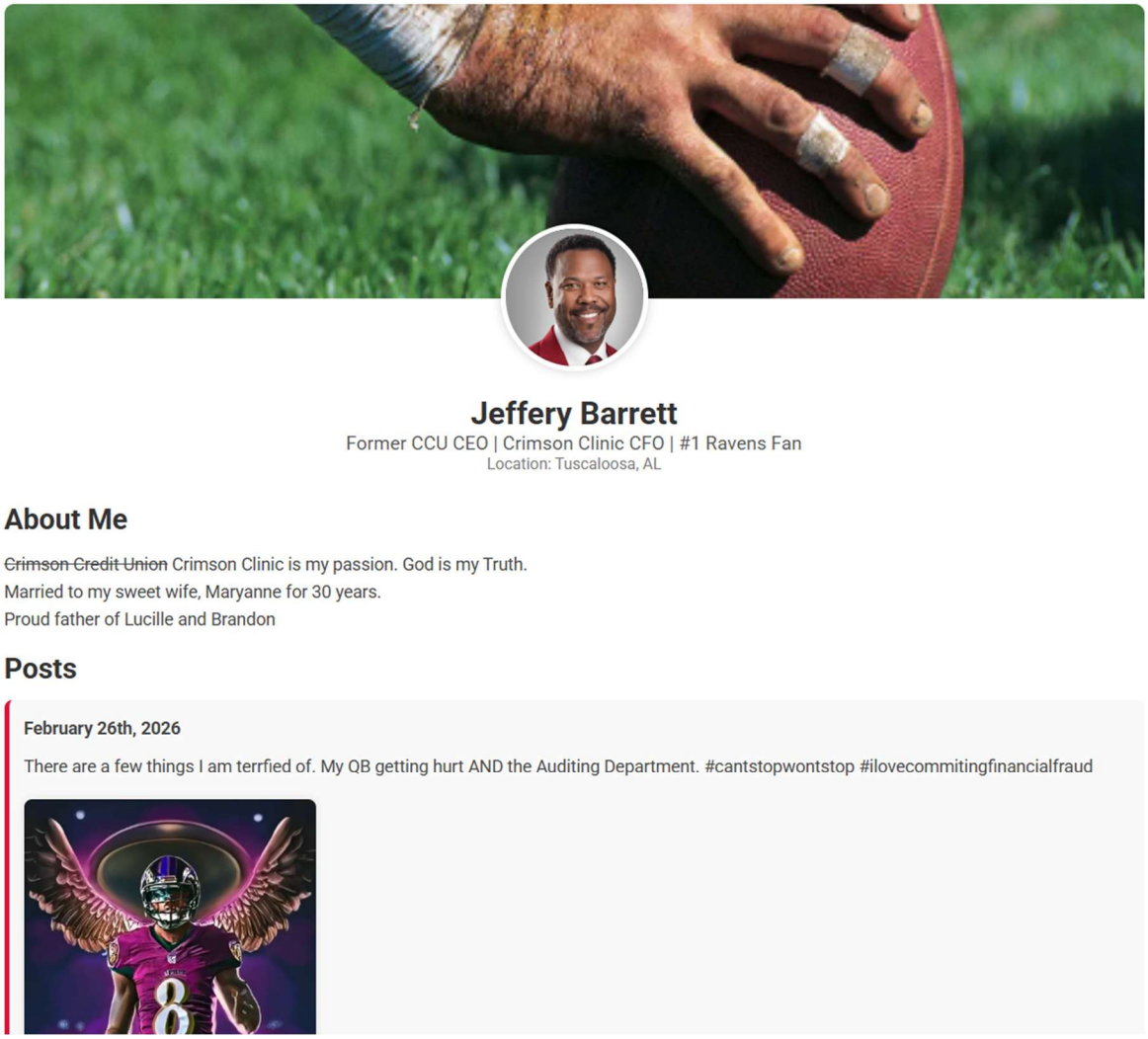


Confidential and Proprietary – Do not duplicate or distribute

Critical Findings

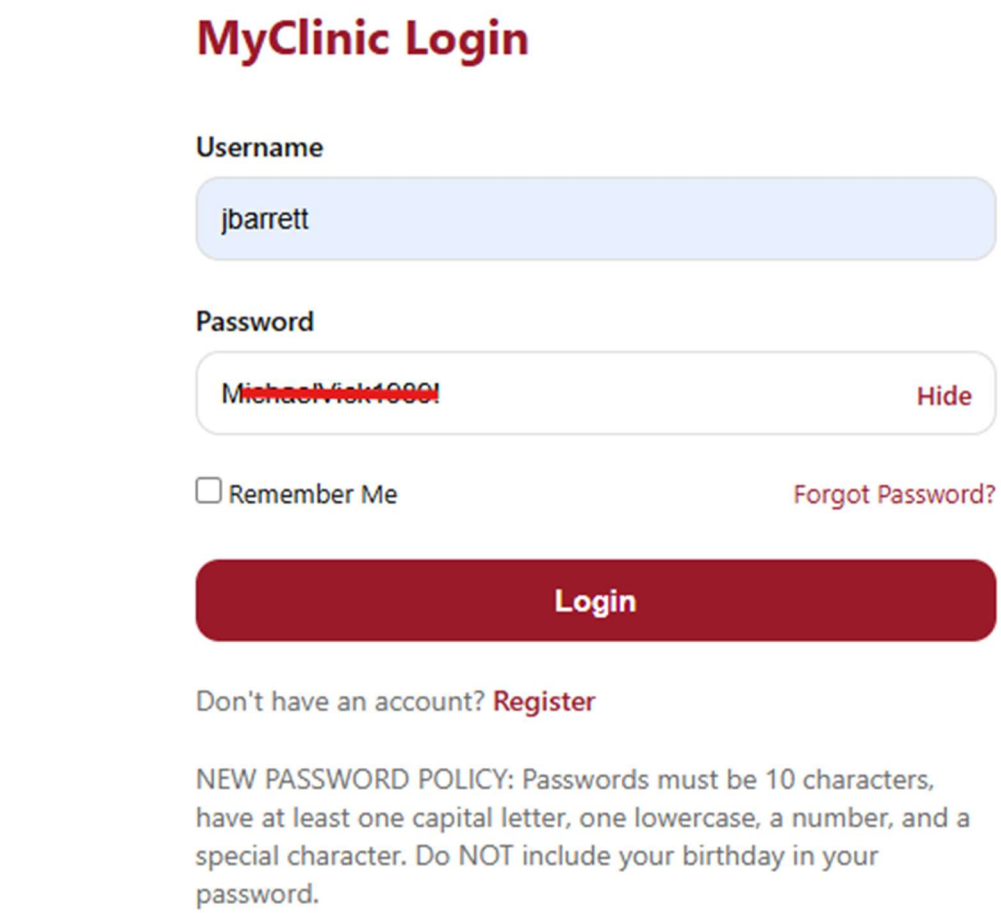
Predictable Password and Insufficient Online Guessing Resistance		CVSS Score	CVSS String
Impact	**Critical**	**9.4 Critical**	**V:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L**
Risk	**High**		
Affected Assets(s)	https://crimsion-clinic/admin-dashboard		
Vulnerability Description	Open Source Intelligence allowed for a password to be constructed and tested against a public-facing admin login page. Additionally, there was no brute force protections to protect against password-stuffing attacks		
Business Impact	Successful administrative authentication provided access to sensitive personnel, payroll, and clinical functions. Depending on authorization enforcement, this can enable disclosure of sensitive data and potentially unauthorized process changes		
MITRE/CWE/OWASP Mapping	CWE-521, CWE307		
Exploitation Procedure			
Due to scoping restrictions, analysts were unable to brute force passwords, but the lack of rate limiting was observed by a lack of protections in web requests intercepted. **1) Locate Open Source Information on the Crimson Social Platform**			

Confidential and Proprietary – Do not duplicate or distribute

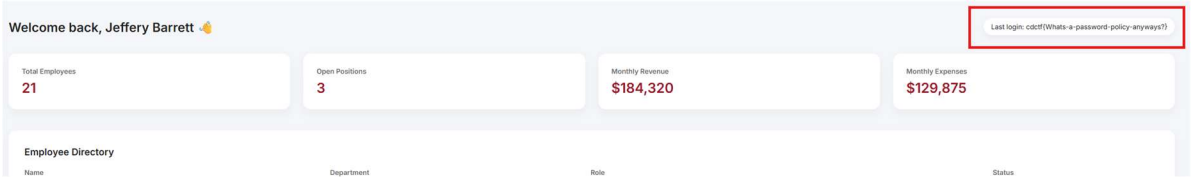


2) **Build a list of potential password candidates based on user profile**
3) **Attempt to login using a created password**

Confidential and Proprietary – Do not duplicate or distribute



4) View the flag



Information Partially Redacted for Security

Recommended Remediation
Require phishing-resistant MFA for privileged and clinical roles. Reject breached and predictable

Confidential and Proprietary – Do not duplicate or distribute

	passwords, including patterns derived from public personal information. Apply per-account and per-source throttling, progressive delays, alerts, and temporary lockout controls. Rotate the compromised password and invalidate existing sessions
References	https://cwe.mitre.org/data/definitions/521.html https://cwe.mitre.org/data/definitions/307.html https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.htm
End Of Block	

Confidential and Proprietary – Do not duplicate or distribute

High Findings

Document Backed Vishing Pretex		CVSS Score	CVSS String
Impact	**Medium**	**8.1 High**	**AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N**
Risk	**High**		
Affected Page(s)	https://crimsion-clinic/medical-dashboard		
Vulnerability Description	The scenario used header and footer elements captured from a diploma available online. The images were altered with AI-assisted editing, then combined with new body content to create an artifact that could support a false identity claim during a vishing interaction		
Business Impact	A successful pretext may cause staff to reset an account, disclose verification information, change a contact method, or grant access. The impact is particularly significant where staff can reach patient, employee, or financial data		
MITRE/CWE/OWASP Mapping	MITRE: T1566.004 Phishing: Spearphishing Voi		
Exploitation Procedure			
1) **Call the Medical Desk** 2) **Understand a diploma is required to verify identity** 3) **Create a false diploma mimicking credentials for a licensed and employed practitioner**			

Confidential and Proprietary – Do not duplicate or distribute

THE REGENTS OF THE

University of California

ON THE NOMINATION OF THE
GRADUATE COUNCIL OF THE IRVINE DIVISION
HAVE CONFERRED UPON

Samuel Matthew Kim

THE DEGREE OF DOCTOR OF SURGERY
IN MEDICINE
WITH ALL THE RIGHTS AND PRIVILEGES THERETO PERTAINING

GIVEN AT IRVINE
THIS SEVENTEENTH DAY OF JUNE IN THE YEAR
NINETEEN HUNDRED AND EIGHTY-NINE

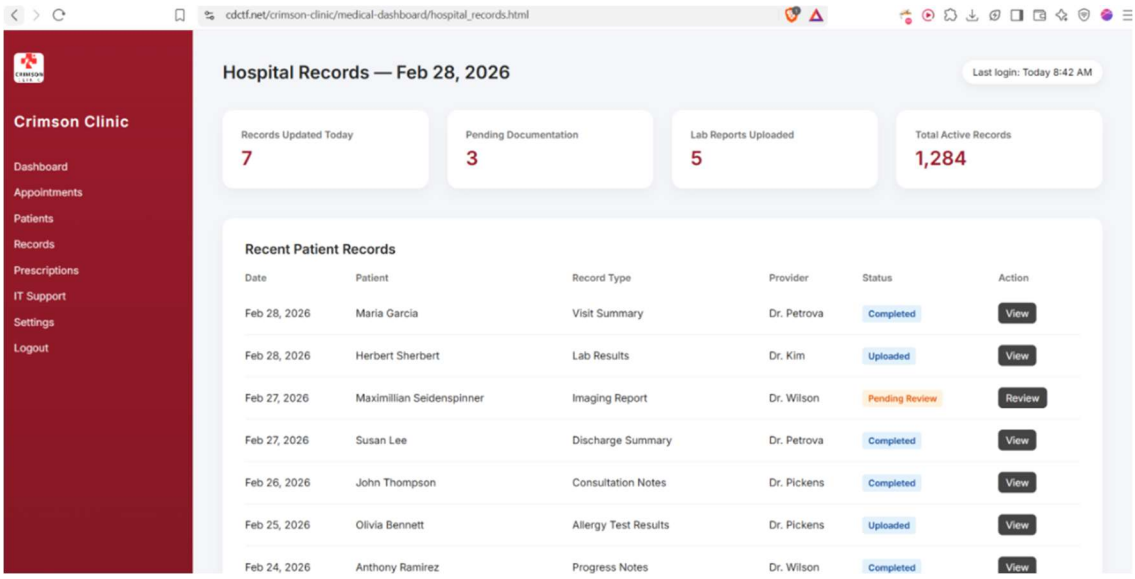
GOVERNOR OF CALIFORNIA AND
PRESIDENT OF THE REGENTS

CHANCELLOR AT IRVINE

PRESIDENT OF THE UNIVERSITY

DEAN OF GRADUATE STUDIES AND
RESEARCH AT IRVINE

4) Receive the credentials for the account and log in



Confidential and Proprietary – Do not duplicate or distribute

Recommended Remediation	
Require independent verification through a pre-registered contact method or identity-provider workflow. Require a second trained employee to approve high-risk requests. Do not accept a document image as the sole proof of identity. Train staff to identify authority, urgency, and document-backed pretexts	
References	https://owasp.org/Top10/2025/A01_2025-Broken_Access_Control/ https://cwiki.apache.org/confluence/display/HTTPD/DirectoryListings
End Of Block	

Confidential and Proprietary – Do not duplicate or distribute

Appendix A: CVSS Severity and Risk Classifications

Προχωρούμε provides these graphics for the assistance of classifying vulnerability severity and risk. These graphics can be used as reference

Severity Rating	Base Score	Explanation
Critical	9.0-10	Vulnerability poses a significant and immediate threat to system and/or network compromise. Potential for severe data compromises and operational disruption.
High	7.0-8.9	Vulnerability poses a threat to system and/or network compromise. Potential for partial or total system compromise and impact on operations.
Medium	4.0-6.9	Vulnerability poses a moderate threat to system and/or network security. Potential of exposing some internal information and/or affecting business operations
Low	0.1-3.9	Vulnerability poses a minimal or limited threat to system and/or network security. Potential for minimal business operation disruption or data leakage.
Informational	0	Vulnerability does not pose any immediate threat to system and/or network security but should be remediated to improve security posture.

Risk Rating	Explanation
Critical	Vulnerability has an extremely high probability of being exploited, either due to its decreased difficulty or due to the availability of the vulnerable system. Almost guaranteed to breach network security or disrupt operations.
High	Vulnerability has a high probability of being exploited, either due to its lower difficulty or availability of the system. Has the potential for operations disruption and network compromise.
Medium	Vulnerability has a moderate probability of being exploited, either due to its difficulty or availability of the system. It has the potential for moderate operations disruption and network compromise.
Low	Vulnerability has a low probability of being exploited, either due to its increased difficulty or low public availability of the system. Has a lower chance of affecting network security or operations.
Informational	Vulnerability has a negligible probability of being exploited, but addressing the vulnerability will improve security posture.

Confidential and Proprietary – Do not duplicate or distribute